

ملخص مختصر)) EchoMind تقرير الأمن السيبراني الشامل - نظام

نظرة عامة

لحماية بيانات المستخدمين والصور الطبية الحساسة، يعتمد على (Defense in Depth) تم تنفيذ نظام أمني متعدد الطبقات مجموعة من الخوارزميات والتقنيات الأمنية المتكاملة.

1. خوارزميات التشفير المستخدمة

خوارزمية تشفير متماثل معتمدة من الحكومة الأمريكية، تستخدم مفتاح 128 بت في وضع - Fernet عبر AES-128** ويتم تخزين المفتاح في متغيرات البيئة. تستخدم لتشفير صور cryptography.fernet، تم تنفيذها باستخدام مكتبة CBC الطبية قبل تخزينها في قاعدة البيانات. عملية التشفير: قراءة بيانات الصورة الخام، تشفيرها بالمفتاح السري، تخزين ECG وفك التشفير يتطلب إدخال المفتاح الصحيح. BinaryField الناتج في

لتجزئة كلمات المرور** - خوارزمية لتوليد مفاتيح من كلمات المرور باستخدام 260,000 تكرار وإضافة PBKDF2** بشكل افتراضي لتخزين كلمات المرور والتحقق من صحتها عند تسجيل Django ملح عشوائي لكل كلمة مرور. يستخدمها (Rainbow Tables) الدخول، وتمنع هجمات الجداول المسبقة.

2. 2. نظام المصادقة الثنائية (FA)

رمز لمرة واحدة مكون من 6 أرقام، صالح لمدة 10 دقائق فقط. يتم إرساله عبر البريد الإلكتروني - OTP آلية عمل** عند طلب تسجيل الدخول أو التسجيل أو استعادة كلمة المرور. كل رمز يُستخدم مرة واحدة فقط، ويمنع هجمات إعادة الاستخدام وانتهاء الصلاحية والتخمين.

تسجيل الدخول كمصادقة OTP التسجيل للتحقق من البريد الإلكتروني عند إنشاء حساب جديد، OTP - OTP** أنواع تسجيل الأيمن لإنشاء حسابات OTP استعادة كلمة المرور للتحقق من الهوية قبل التغيير، و OTP إضافية بعد كلمة المرور، المسؤولين.

3. حماية جلسات المستخدمين

آلية إدارة الجلسات - يتم إنشاء جلسة مؤقتة عند بدء التسجيل، تخزن بيانات المستخدم المؤقتة (البريد، اسم المستخدم، فريد، وتنتهي بعد وقت محدد. لا يتم حفظ OTP كلمة المرور المشفرة، وقت الإنشاء، نوع العملية). يتم ربط الجلسة برمز

ويتم تنظيف الجلسة فوراً بعد اكتمال العملية. OTP المستخدم في قاعدة البيانات قبل التحقق من

4. تسجيل ومراقبة الأنشطة

والوقت والمستخدم لكل محاولة دخول. يمكن للمستخدم رؤية آخر IP **سجل تاريخ تسجيل الدخول** - يتم تسجيل عنوان 10 محاولات، ويمكن للمسؤول مراقبة كل المحاولات.

IP **تنبيهات البريد الإلكتروني التلقائية** - يتم إرسال بريد فوري لكل عملية تسجيل دخول ناجحة، يحتوي على عنوان ووقت الدخول، لإشعار المستخدم بأي دخول غير مصرح به.

5. التحكم في الوصول والصلاحيات

يفحص كل طلب ويسمح فقط للمسارات العامة. الطبقة الثانية: Middleware **طبقات حماية المسارات** - الطبقة الأولى: View الطبقة الثالثة: تحقق إضافي داخل @staff_member_required و @login_required مثل Decorators مع رسالة خطأ مخصصة.

عرض تاريخه الطبي، التواصل مع ECG **نظام صلاحيات المستخدمين** - المستخدم العادي: تسجيل دخول، رفع صور الدعم. المسؤول: كل صلاحيات المستخدم العادي، لوحة تحكم الأيمن، عرض جميع رسائل المستخدمين، فك تشفير وعرض تحليل الصور بالذكاء الاصطناعي، إضافة ملاحظات طبية. المطور: كل صلاحيات المسؤول، والوصول إلى ECG صور Django Admin.

6. حماية الملفات والصور الطبية

استراتيجية التشفير - عند رفع الصورة، يتم قراءة البيانات الخام، تشغيل نموذج الذكاء الاصطناعي للتحليل الأولي، ثم تخزين البيانات المشفرة في قاعدة البيانات. لفك التشفير، يجب على المسؤول Fernet تشفير الصورة فوراً باستخدام دون تخزين Base64 إدخال المفتاح السري. عند عرض المستخدم لتاريخه، يتم فك التشفير مؤقتاً وتحويل الصورة إلى محلي.

يتم فحص PNG, JPG, JPEG, GIF, WEBP, PDF, DOC, DOCX, TXT **تحديد أنواع الملفات** - المسموحة: الامتداد ونوع المحتوى، ورفض أي ملف غير متوافق.

##7. حماية عمليات استعادة كلمة المرور

OTP **آلية استعادة كلمة المرور** - يدخل المستخدم بريده، يتحقق النظام من وجوده (دون كشف النتيجة)، يتم إنشاء مخصص وإرساله للبريد، يبقى صالحاً 10 دقائق. بعد إدخال الرمز الصحيح، يتم وضع علامة "متحقق" في الجلسة. ينتقل المستخدم إلى صفحة تعيين كلمة مرور جديدة بعد التحقق من العلامة، ثم يتم تجزئة كلمة المرور الجديدة وتخزينها، وحذف بيانات الجلسة، وإعادة التوجيه إلى صفحة تسجيل الدخول.

##8. حماية نماذج الإدخال

فقط، غير مستخدم. اسم المستخدم: اختياري. Gmail **التحقق من صحة البيانات** - البريد الإلكتروني: صيغة صحيحة، كلمة المرور: قوية (8 أحرف، ليست شائعة، ليست رقمية بالكامل)، مع تأكيد التطابق. نماذج الاتصال: التحقق من وجود تحديد الحد الأقصى لطول النصوص. كلمة مرور (Django) جميع الحقول، منع إدخال السكريبتات الضارة (تلقائياً من الأيمن: مقارنة مع القيمة المخزنة في الإعدادات لمنع إنشاء حسابات أدمن بدونها.

##9. نظام الإشعارات الأمنية

والوقت. IP **أنواع الإشعارات** - إشعارات تسجيل الدخول: تُرسل لكل عملية دخول ناجحة عبر البريد، تحتوي على إشعارات الرد على الرسائل: تنبيه المستخدم بوجود رد مع رابط مباشر. إشعارات النظام: تنبيه المسؤولين بالرسائل الجديدة وتحديثات الحالة. إشعارات الرسائل الجديدة: إشعار جميع المسؤولين عند إرسال مستخدم رسالة، وإشعار المستخدم فقط عند رد المسؤول. تُخزن الإشعارات في قاعدة البيانات مع حالة القراءة.

##10. الحماية من هجمات الويب الشائعة

خام. SQL بنسبة 100%، وعدم استخدام استعلامات Django ORM استخدام - **SQL Injection**

إلى HTML كل نص يتم عرضه في القوالب، تحويل علامات (escape) يقوم تلقائياً بتنظيف Django - **XSS** كيانات.

فريد لكل جلسة، يتم التحقق منه عند كل طلب. CSRF محمية برمز POST جميع نماذج - **CSRF**

يجعل تخمين كلمة المرور غير مجدٍ، رمز 6 أرقام (مليون احتمال)، صلاحية قصيرة OTP استخدام - **Brute Force**

(10 دقائق).

11. أمان الملفات المرفوعة في قاعدة البيانات

media في قاعدة البيانات، المرفقات العادية تُخزن في مجلد BinaryField **التخزين الآمن** - الصور المشفرة تُخزن في Views. كل الوصول يتم عبر URL المحمي. لا يمكن الوصول المباشر عبر

12. أمان نقل البيانات

لتشفير كل البيانات المرسلة. يوصى باستخدام SSL/TLS عبر شهادة HTTPS في بيئة الإنتاج، يجب تفعيل - **HTTPS**
(HttpOnly و Secure) واستخدام كوكيز آمنة، HTTPS إلى HTTP إعادة توجيه تلقائي من HSTS.

13. سجل التدقيق (Audit Log)

سجل الرسائل (المرسل، الوقت، الحالة)، سجل تحليل (IP ما يتم تسجيله) - سجل تسجيل الدخول (من، متى، من أي) **
من رفع الصورة، وقت الرفع، نتيجة التحليل، من قام بالتحليل)، سجل تغييرات الحساب (تغيير كلمة المرور، تحديث (ECG
الملف الشخصي، حذف الحساب).

14. إدارة المفاتيح السرية

Fernet لتوقيع الجلسات والكوكيز. مفتاح تشفير (SECRET_KEY) السري Django **أنواع المفاتيح** - مفتاح
كلمة مرور تسجيل الأدمن. (Base64 بايت بصيغة 32) ECG لتشفير صور (ENCRYPTION_KEY)
لمنع إنشاء حسابات أدمن بدونها. مفتاح البريد الإلكتروني (ADMIN_REGISTRATION_PASSWORD)
SMTP. للاتصال بخادم (EMAIL_HOST_PASSWORD).

env. التخزين الآمن - لا يتم تخزين المفاتيح في كود المصدر أو قاعدة البيانات، بل في متغيرات البيئة أو ملف **
Git. المستبعد من

15. التحقق من صحة البيانات.

غير مستخدم؛ كلمة مرور قوية (8 أحرف، ليست شائعة، ليست Gmail، قواعد التحقق - التسجيل: البريد صحيح، رقمية بالكامل) مع تأكيد التطابق. الملف الشخصي: اسم المستخدم اختياري (حد أقصى 50 حرف)، صورة شخصية بنوع ملف صحيح. الاتصال: الاسم مطلوب، بريد صحيح، رقم هاتف مع رمز الدولة، موضوع من قائمة محددة، مرفق من نوع مسموح. الرد على الرسالة (للمسؤول): نص الرد مطلوب، حالة وألوية من قائمة محددة.

16. خلاصة الإجراءات الأمنية

FA متقدم. المصادقة (2: PBKDF2 + Salt) متقدم. كلمات المرور: (AES-128/Fernet) نقاط القوة - تشفير الصور (ORM + Validation) متقدم. حماية البيانات: (Middleware + Decorators) متقدم. التحكم بالوصول: (OTP) عبر متقدم. التسجيل والمراقبة: متوسط. إدارة الجلسات: متوسط. (CSRF + XSS) متقدم. حماية الويب

هجمات إعادة ، (OTP عبر) Brute Force، CSRF، XSS، SQL Injection، التهديدات التي يتم مواجهتها - استخدام الرموز، هجمات تسريب البيانات (عبر التشفير)، هجمات رفع الملفات الضارة، هجمات تجاوز الصلاحيات.

تسجيل ، Google Authenticator عبر FA تفعيل 2، reCAPTCHA، إضافة Rate Limiting، التوصيات - تفعيل في بيئة الإنتاج، تشفير قاعدة HTTPS الخروج التلقائي بعد فترة عدم نشاط، مراجعة أمنية دورية وتحديث التبعيات، تفعيل (TDE). البيانات بالكامل